

Міністерство освіти і науки України
Львівський національний університет імені Івана Франка
Факультет електроніки та комп'ютерних технологій

ЗВІТ

про виконання лабораторної роботи № 10
з курсу “Інформаційна безпека програм та даних”
на тему: “Виявлення та аналіз веб-вразливостей у середовищі
OWASP Juice Shop”

Виконав:

Студент. гр. ФеП-41 Фіняк Олег

Перевірив:

Павлик М.Р.

Львів – 2026

Мета роботи. Набуття практичних навичок виявлення, аналізу та експлуатації вразливостей веб-додатків відповідно до OWASP Top 10 з використанням OWASP Juice Shop.

Порядок виконання лабораторної роботи

1. Розгортання середовища 1. Встановіть Juice Shop:

через Node.js: git clone <https://github.com/juice-shop/juice-shop.git>

```
Finik@DESKTOP-DD0VU84 MINGW64 /c/Users/Finik/Desktop
$ git clone https://github.com/juice-shop/juice-shop.git
Cloning into 'juice-shop'...
remote: Enumerating objects: 154414, done.
remote: Counting objects: 100% (4/4), done.
remote: Compressing objects: 100% (3/3), done.
remote: Total 154414 (delta 1), reused 1 (delta 1), pack-reused 154410 (from 2)
Receiving objects: 100% (154414/154414), 276.54 MiB | 7.97 MiB/s, done.
Resolving deltas: 100% (120349/120349), done.
```

cd juice-shop

npm install

npm start

```
Finik@DESKTOP-DD0VU84 MINGW64 /c/Users/Finik/Desktop/juice-shop (master)
$ npm start

> juice-shop@19.2.1 start
> node build/app

info: Detected Node.js version v24.14.0 (OK)
info: Detected OS win32 (OK)
info: Detected CPU x64 (OK)
info: Configuration default validated (OK)
info: Entity models 20 of 20 are initialized (OK)
info: Required file server.js is present (OK)
info: Required file styles.css is present (OK)
info: Required file index.html is present (OK)
info: Required file main.js is present (OK)
info: Required file polyfills.js is present (OK)
info: Required file matching /^hacking-instructor-.+\.js$/ is present (OK)
info: Port 3000 is available (OK)
info: Chatbot training data botDefaultTrainingData.json validated (OK)
info: Domain https://www.alchemy.com/ is reachable (OK)
info: Server listening on port 3000
```

2. Відкрийте додаток у браузері:

<http://localhost:3000>

2. Ознайомлення з інтерфейсом

Проаналізуйте:

- структуру веб-додатку;
- основні функції (реєстрація, логін, покупки);
- механізм підказок (Score Board).

You successfully solved a challenge: Score Board (Find the carefully hidden 'Score Board' page.)

X

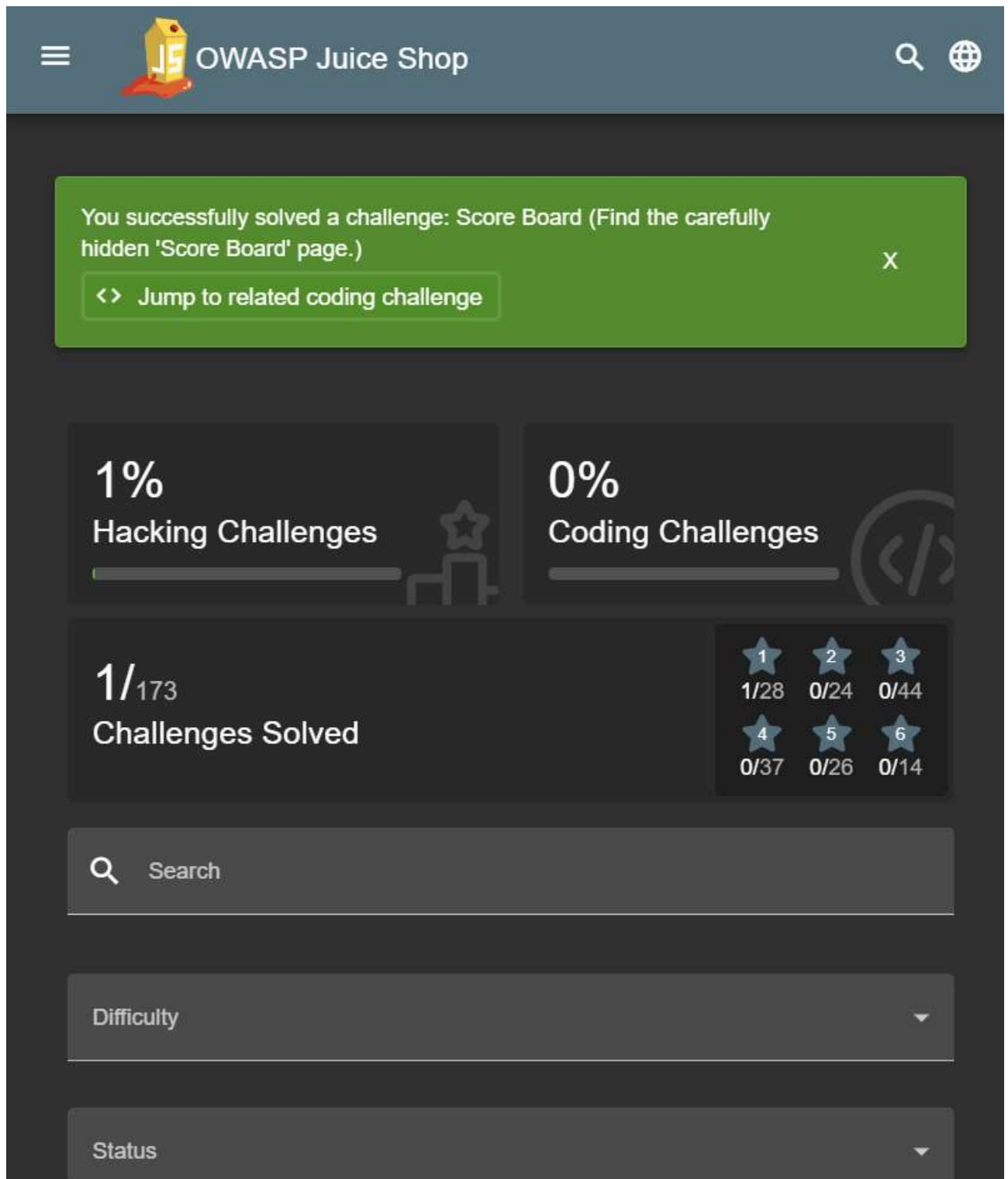
<> [Jump to related coding challenge](#)

All Products



Apple Juice (1000ml)

1.99₺



3. Виконання практичних завдань

Студент повинен виконати серію завдань (мінімум 5–8), наприклад:

Завдання 1. Аналіз автентифікації

- проаналізуйте форму логіну;
- спробуйте обійти автентифікацію (SQL Injection).

Login

Email*

' OR 1=1 --

Password*

12345



Forgot your password?

 Log in

☐ Remember me

or

 Log in with
Google

Not yet a customer?

You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)

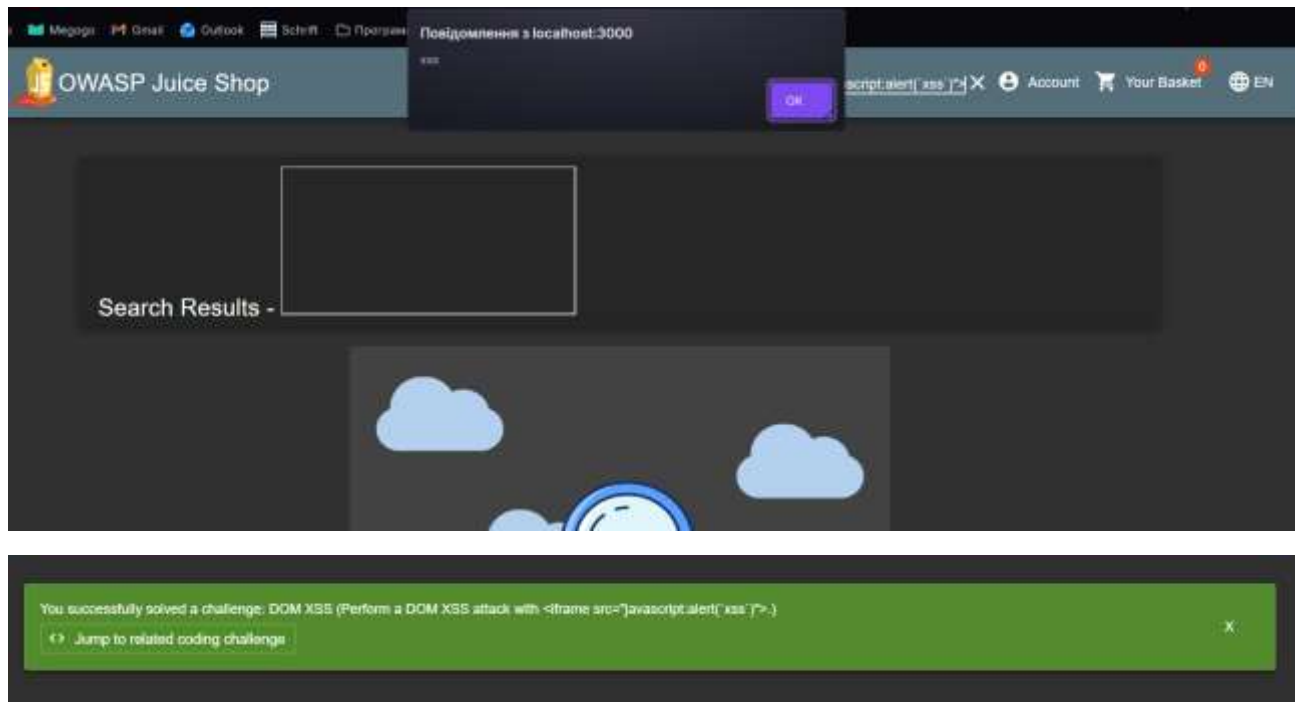
X

[<> Jump to related coding challenge](#)

Завдання 2. XSS-атака

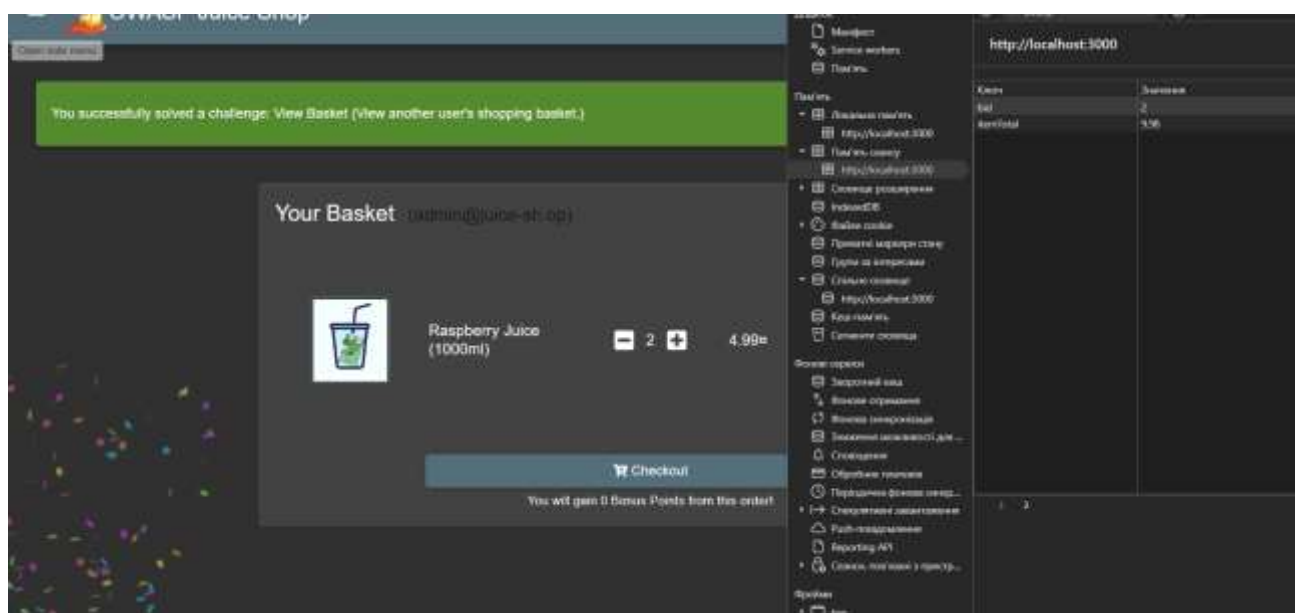
- знайдіть поле введення (наприклад, відгуки);

- реалізуйте reflected або stored XSS.



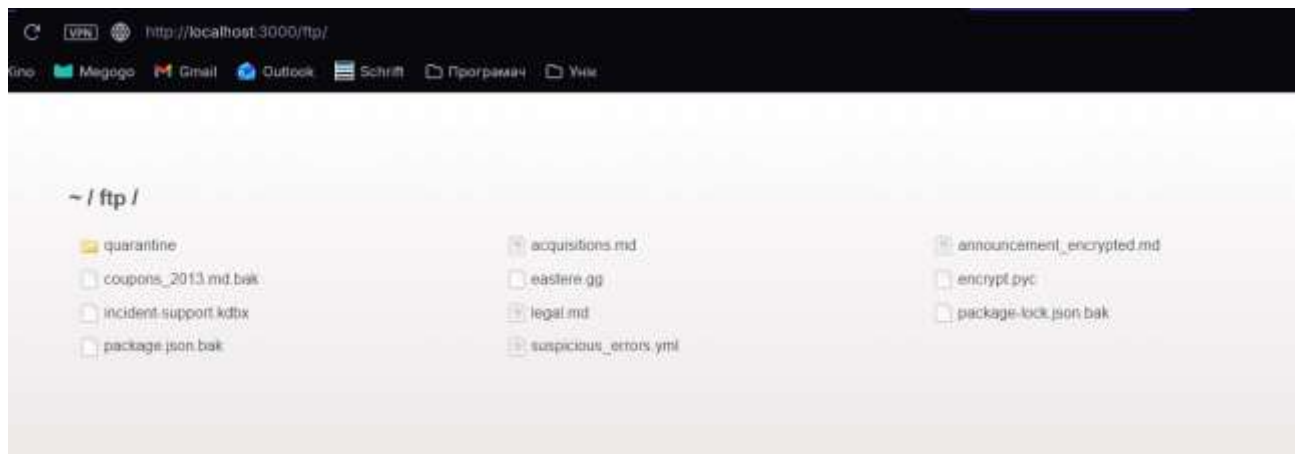
Завдання 3. Broken Access Control

- спробуйте отримати доступ до ресурсів без авторизації;
- змініть параметри запиту (IDOR).



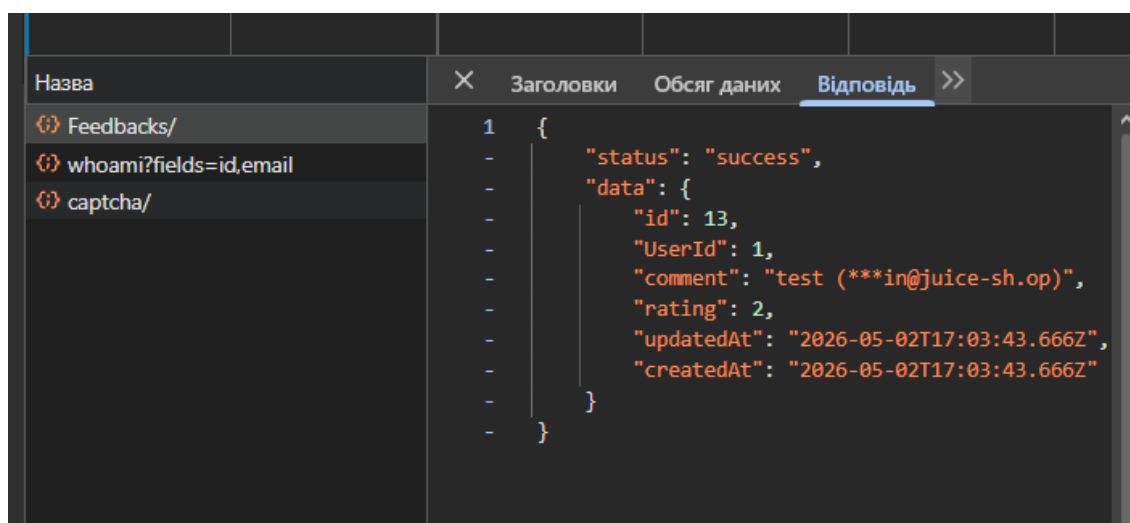
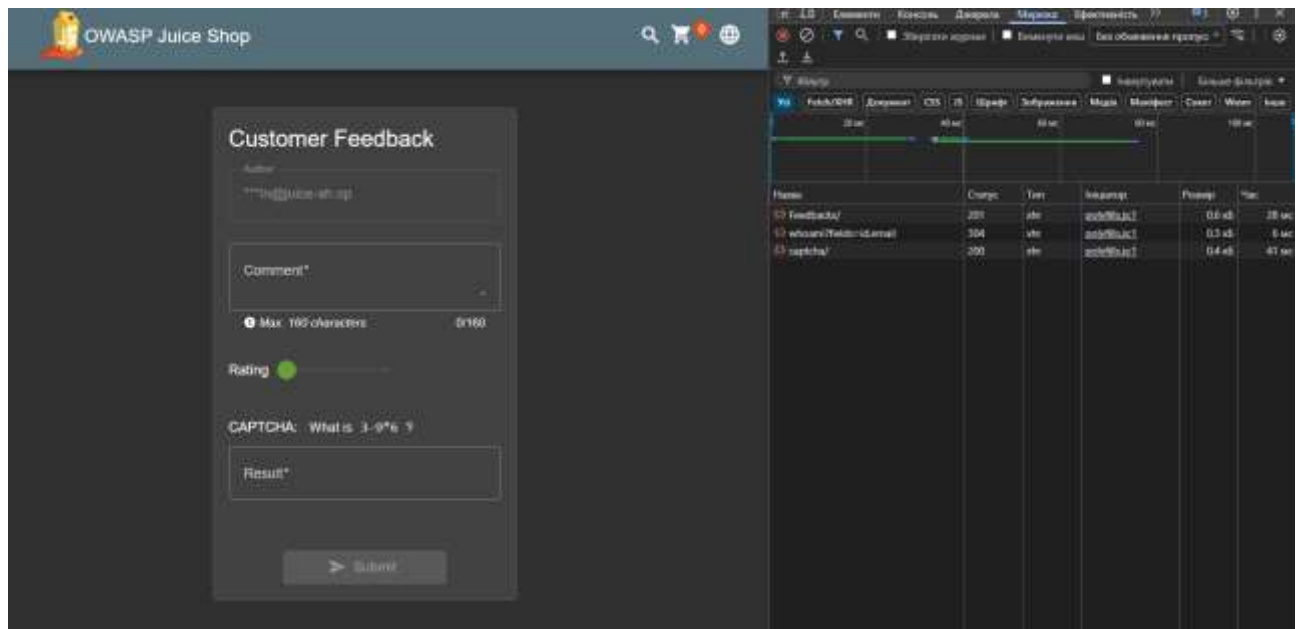
Завдання 4. Sensitive Data Exposure

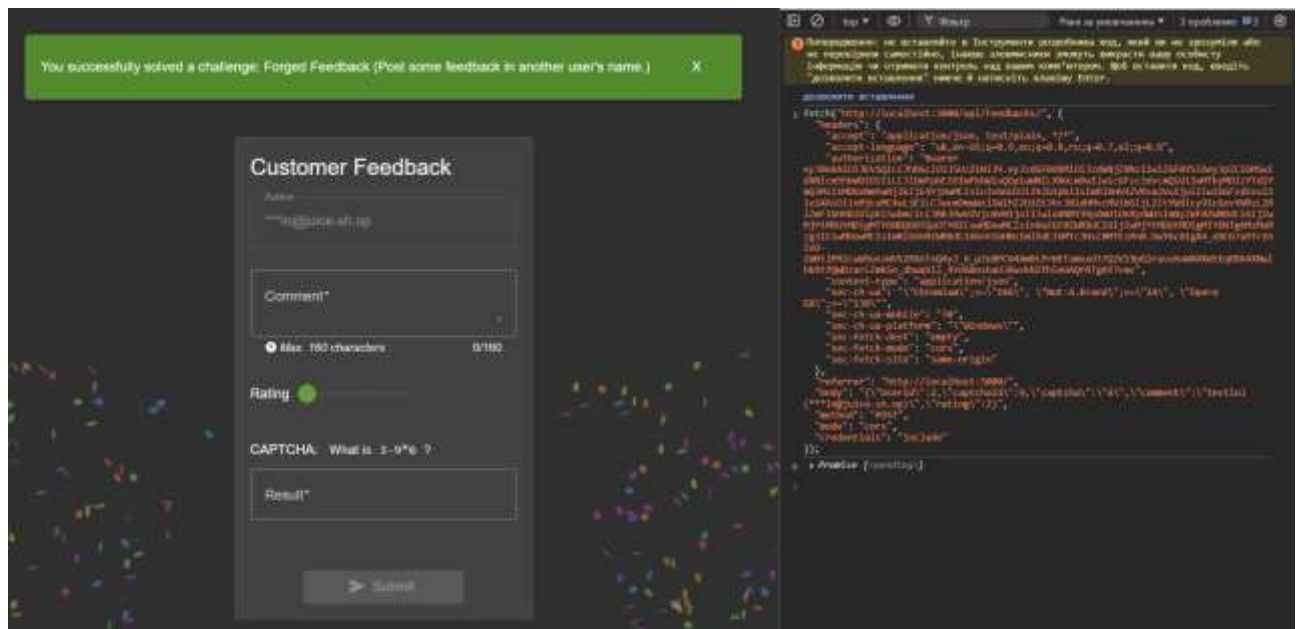
- знайдіть приховані дані (API, конфігурації);
- використайте DevTools.



Завдання 5. API-аналіз

- перехопіть HTTP-запити через Burp Suite;
- модифікуйте запити.





Висновок: Під час виконання лабораторної роботи було розгорнуто навчальне середовище OWASP Juice Shop та практично досліджено найпоширеніші вразливості веб-додатків згідно з переліком OWASP Top 10. Використовуючи підхід Capture the Flag, було успішно проведено аналіз механізмів автентифікації, реалізовано SQL-ін'єкції та XSS-атаки, а також виявлено недоліки контролю доступу і витіки чутливих даних через інструменти розробника та перехоплення HTTP-запитів.